Security Hotspots

0.0% Security Hotspots Reviewed

To review | Acknowledged | Fixed | Safe

69 Security Hotspots to review

Review priority: High

Authentication 1

Make sure no write permissions are assigned to the copied resource.

1 extra location

Sensitive file owner.

Cross-Site Scripting (XSS) 9

Review priority: Medium

Code Injection (RCE) 5

Denial of Service (DoS) 8

Permission 1

Weak Cryptography 11

Review priority: Low

Make sure no write permissions are assigned to the copied resource.

Allowing non-root users to modify resources copied to an image is security-sensitive **docker:S6504**

Status: To review
This security hotspot needs to be reviewed to assess whether the code poses a risk.

Review

Review priority: High

Category: Authentication

Assignee: Not assigned

Where is the risk? | Activity

/Dockerfile

Show previous few lines of code

```
28      org.opencontainers.image.authors="Bjoern Kimminich <bjoern.kimminich@owasp.org>" \
29      org.opencontainers.image.vendor="Open Worldwide Application Security Project" \
30      org.opencontainers.image.documentation="https://help.owasp-juice.shop" \
31      org.opencontainers.image.licenses="MIT" \
32      org.opencontainers.image.version="19.1.1" \
33      org.opencontainers.image.url="https://owasp-juice.shop" \
34      org.opencontainers.image.source="https://github.com/juice-shop/juice-shop" \
35      org.opencontainers.image.revision=$VCS_REF \
36      org.opencontainers.image.created=$BUILD_DATE
37  WORKDIR /juice-shop
38  COPY --from=installer --chown=65532:0 /juice-shop .
```

Make sure no write permissions are assigned to the copied resource.

```
39  USER 65532
40  EXPOSE 3000
41  CMD ["/juice-shop/build/app.js"]
42
```

Security Hotspots

0.0% Security Hotspots Reviewed

To review | Acknowledged | Fixed | Safe

69 Security Hotspots to review

Review priority: High

Authentication 1

Cross-Site Scripting (XSS) 9

Make sure disabling Angular built-in sanitization is safe here.

Make sure disabling Angular built-in sanitization is safe here.

Make sure disabling Angular built-in sanitization is safe here.

Make sure disabling Angular built-in sanitization is safe here.

Make sure disabling Angular built-in sanitization is safe here.

Make sure disabling Angular built-in sanitization is safe here.

Make sure disabling Angular built-in sanitization is safe here.

Make sure disabling Angular built-in sanitization is safe here.

Review priority: Medium

Code Injection (RCE) 5

Denial of Service (DoS) 8

Permission 1

Weak Cryptography 11

Review priority: Low

Make sure disabling Angular built-in sanitization is safe here.

Disabling Angular built-in sanitization is security-sensitive **typescript:S6268**

Status: To review
This security hotspot needs to be reviewed to assess whether the code poses a risk.

Review

Review priority:
High

Category:
Cross-Site Scripting (XSS)

Assignee:
Not assigned

Where is the risk? | Activity

frontend/src/app/about/about.component.ts

Show previous few lines of code

```
109           console.error(err)
110           return EMPTY
111         })
112       )
113       .subscribe((feedbacks) => {
114         for (let i = 0; i < feedbacks.length; i++) {
115
116           feedbacks[i].comment = `<figcaption><p style="margin-bottom: 0;">${
117             feedbacks[i].comment
118           }</p><div class="feedback-stars">(${this.stars[feedbacks[i].rating]})</div></figcaption>`
119           feedbacks[i].comment = this.sanitizer.bypassSecurityTrustHtml(
```

Make sure disabling Angular built-in sanitization is safe here.

```
120             feedbacks[i].comment
121           )
122
123           this.galleryRef.addImage({
124             src: this.images[i % this.images.length],
125             args: feedbacks[i].comment
126           })
127         }
128       })
129   }
```

Show next few lines of code

Security Hotspots

0.0% Security Hotspots Reviewed

To review | Acknowledged | Fixed | Safe

69 Security Hotspots to review

Review priority: High

- **Authentication** 1
- **Cross-Site Scripting (XSS)** 9

Review priority: Medium

- **Code Injection (RCE)** 5
  - Make sure that this dynamic injection or execution of code is safe.
  - Make sure that this dynamic injection or execution of code is safe.
  - Make sure that this dynamic injection or execution of code is safe.
  - Make sure that this dynamic injection or execution of code is safe.
  - Make sure that this dynamic injection or execution of code is safe.
- **Denial of Service (DoS)** 8
- **Permission** 1
- **Weak Cryptography** 11

Review priority: Low

- **Encryption of Sensitive Data** 27
- **Insecure Configuration** 2
- **Others** 5

69 of 69 shown

Make sure that this dynamic injection or execution of code is safe.

Dynamically executing code is security-sensitive **typescript:S1523**

Status: To review
This security hotspot needs to be reviewed to assess whether the code poses a risk.

Review

Review priority: Medium

Category: Code Injection (RCE)

Assignee: Not assigned

Where is the risk? | Activity

routes/b2bOrder.ts

Show previous few lines of code

```
13  import * as security from '../lib/insecurity'
14  import * as utils from '../lib/utils'
15
16  export function b2bOrder () {
17    return ({ body }: Request, res: Response, next: NextFunction) => {
18      if (utils.isChallengeEnabled(challenges.rceChallenge) || utils.isChallengeEnabled(challenges.rceOccupyChallenge)) {
19        const orderLinesData = body.orderLinesData || ''
20        try {
21          const sandbox = { safeEval, orderLinesData }
22          vm.createContext(sandbox)
23          vm.runInContext('safeEval(orderLinesData)', sandbox, { timeout: 2000 })
```

Make sure that this dynamic injection or execution of code is safe.

```
24          res.json({ cid: body.cid, orderNo: uniqueOrderNumber(), paymentDue: dateTwoWeeksFromNow() })
25        } catch (err) {
26          if (utils.getErrorMessage(err).match(/Script execution timed out.*/) != null) {
27            challengeUtils.solveIf(challenges.rceOccupyChallenge, () => { return true })
28            res.status(503)
29            next(new Error('Sorry, we are temporarily not available! Please try again later.'))
30          } else {
31            challengeUtils.solveIf(challenges.rceChallenge, () => { return utils.getErrorMessage(err) ===
'Infinite loop detected - reached max iterations' })
32            next(err)
33          }
```

Show next few lines of code

Security Hotspots

0.0% Security Hotspots Reviewed

To review | Acknowledged | Fixed | Safe

69 Security Hotspots to review

Review priority: High

- Authentication 1
- Cross-Site Scripting (XSS) 9

Review priority: Medium

- Code Injection (RCE) 5
- Denial of Service (DoS) 8
- Permission 1
- Weak Cryptography 11

Review priority: Low

- Encryption of Sensitive Data 27
- Insecure Configuration 2
- Others 5

69 of 69 shown

Make sure the regex used here, which is vulnerable to super-linear runtime due to backtracking, cannot lead to denial of service.

Using slow regular expressions is security-sensitive **typescript:S5852**

Status: To review
This security hotspot needs to be reviewed to assess whether the code poses a risk.

Review

Review priority:
Medium

Category:
Denial of Service (DoS)

Assignee:
Not assigned

Where is the risk? | Activity

frontend/src/app/change-password/change-password.component.ts

Show previous few lines of code

```
82          () => {
83            this.changePassword()
84          }
85        )
86      }
87
88      changePassword () {
89        if (
90          localStorage.getItem('email')?.match(/support@.*/) &&
91          !this.newPasswordControl.value.match(
92            /(?=.*[a-z])(?=.*[A-Z])(?=.*\d)(?=.*[@$!%*?&])[A-Za-z\d@$!%*?&]{12,30}/
```

Make sure the regex used here, which is vulnerable to super-linear runtime due to backtracking, cannot lead to denial of service.

```
93          )
94        ) {
95          console.error(
96
'Parola echipei de asistență nu respectă politica corporativă pentru conturile privilegiate! Vă rugăm să schimbați parola în consecință!'
97          )
98        }
99        this.userService
100         .changePassword({
101           current: this.passwordControl.value,
102           new: this.newPasswordControl.value,
```

Show next few lines of code

Security Hotspots

0.0% Security Hotspots Reviewed

To review | Acknowledged | Fixed | Safe

69 Security Hotspots to review

Review priority: High

- **Authentication** 1
- **Cross-Site Scripting (XSS)** 9

Review priority: Medium

- **Code Injection (RCE)** 5
- **Denial of Service (DoS)** 8

  Make sure the regex used here, which is vulnerable to super-linear runtime due to backtracking, cannot lead to denial of service.

  Make sure the regex used here, which is vulnerable to super-linear runtime due to backtracking, cannot lead to denial of service.

  Make sure the regex used here, which is vulnerable to super-linear runtime due to backtracking, cannot lead to denial of service.

  Make sure the regex used here, which is vulnerable to super-linear runtime due to backtracking, cannot lead to denial of service.

  Make sure the regex used here, which is vulnerable to super-linear runtime due to backtracking, cannot lead to denial of service.

  Make sure the regex used here, which is vulnerable to super-linear runtime due to backtracking, cannot lead to denial of service.

  Make sure the regex used here, which is vulnerable to super-linear runtime due to backtracking, cannot lead to denial of service.

  Make sure the content length limit is safe here.

- **Permission** 1

Make sure the content length limit is safe here.

Allowing requests with excessive content length is security-sensitive **typescript:S5693**

Status: To review
This security hotspot needs to be reviewed to assess whether the code poses a risk.

Review

Review priority:
Medium

Category:
Denial of Service (DoS)

Assignee:
Not assigned

Where is the risk? | Activity

/server.ts

Show previous few lines of code

```
672   }).catch((err) => {
673     console.error(err)
674   })
675
676   const uploadToMemory = multer({ storage: multer.memoryStorage(), limits: { fileSize: 200000 } })
677   const mimeTypeMap: any = {
678     'image/png': 'png',
679     'image/jpeg': 'jpg',
680     'image/jpg': 'jpg'
681   }
682   const uploadToDisk = multer({
        Make sure the content length limit is safe here.
683     storage: multer.diskStorage({
684       destination: (req: Request, file: any, cb: any) => {
685         const isValid = mimeTypeMap[file.mimetype]
686         let error: Error | null = new Error('Invalid mime type')
687         if (isValid) {
688           error = null
689         }
690         cb(error, path.resolve('frontend/dist/frontend/assets/public/images/uploads/'))
691       },
692       filename: (req: Request, file: any, cb: any) => {
```

Show next few lines of code

Security Hotspots

0.0% Security Hotspots Reviewed

To review | Acknowledged | Fixed | Safe

69 Security Hotspots to review

Review priority: High

- Authentication 1
- Cross-Site Scripting (XSS) 9

Review priority: Medium

- Code Injection (RCE) 5
- Denial of Service (DoS) 8
- Permission 1

> Copying recursively might inadvertently add sensitive data to the container. Make sure it is safe here.

- Weak Cryptography 11

Review priority: Low

- Encryption of Sensitive Data 27
- Insecure Configuration 2
- Others 5

69 of 69 shown

Copying recursively might inadvertently add sensitive data to the container. Make sure it is safe here.

Recursively copying context directories is security-sensitive **docker:S6470**

Status: To review
This security hotspot needs to be reviewed to assess whether the code poses a risk.
Review

Review priority: Medium
Category: Permission
Assignee: Not assigned

Where is the risk? | Activity

/Dockerfile

```
1  FROM node:22 AS installer
2  COPY . /juice-shop
```

> Copying recursively might inadvertently add sensitive data to the container. Make sure it is safe here.

```
3  WORKDIR /juice-shop
4  RUN npm i -g typescript ts-node
5  RUN npm install --omit=dev --unsafe-perm
6  RUN npm dedupe --omit=dev
7  RUN rm -rf frontend/node_modules
8  RUN rm -rf frontend/.angular
9  RUN rm -rf frontend/src/assets
10 RUN mkdir logs
11 RUN chown -R 65532 logs
12 RUN chgrp -R 0 ftp/ frontend/dist/ logs/ data/ i18n/
```

Show next few lines of code

Security Hotspots

0.0% Security Hotspots Reviewed

Denial of Service (DoS) 8

Permission 1

Weak Cryptography 11

- Make sure that using this pseudorandom number generator is safe here.
- Make sure that using this pseudorandom number generator is safe here.
- Make sure that using this pseudorandom number generator is safe here.
- Make sure that using this pseudorandom number generator is safe here.
- Make sure that using this pseudorandom number generator is safe here.
- Make sure that using this pseudorandom number generator is safe here.
- Make sure that using this pseudorandom number generator is safe here.
- Make sure that using this pseudorandom number generator is safe here.
- Make sure that using this pseudorandom number generator is safe here.
- Make sure that using this pseudorandom number generator is safe here.
- Make sure that using this pseudorandom number generator is safe here.

Review priority: Low

Encryption of Sensitive Data 27

Insecure Configuration 2

Others 5

69 of 69 shown

Make sure that using this pseudorandom number generator is safe here.

Using pseudorandom number generators (PRNGs) is security-sensitive **typescript:S2245**

Status: To review
This security hotspot needs to be reviewed to assess whether the code poses a risk.

Review

Review priority: Medium

Category: Weak Cryptography

Assignee: Not assigned

Where is the risk? | Activity

data/datacreator.ts

Show previous few lines of code

```
237  async function createRandomFakeUsers () {
238    function getGeneratedRandomFakeUserEmail () {
239      const randomDomain = makeRandomString(4).toLowerCase() + '.' + makeRandomString(2).toLowerCase()
240      return makeRandomString(5).toLowerCase() + '@' + randomDomain
241    }
242
243    function makeRandomString (length: number) {
244      let text = ''
245      const possible = 'ABCDEFGHIJKLMNOPQRSTUVWXYZabcdefghijklmnopqrstuvwxyz0123456789'
246
247      for (let i = 0; i < length; i++) { text += possible.charAt(Math.floor(Math.random() * possible.length)) }
```

Make sure that using this pseudorandom number generator is safe here.

```
248
249      return text
250    }
251
252    return await Promise.all(new Array(config.get('application.numberOfRandomFakeUsers')).fill(0).map(
253      async () => await UserModel.create({
254        email: getGeneratedRandomFakeUserEmail(),
255        password: makeRandomString(5)
256      })
257    ))
```

Show next few lines of code

Security Hotspots

0.0% Security Hotspots Reviewed

Permission 1

Weak Cryptography 11

Review priority: Low

Encryption of Sensitive Data 27

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using http protocol is insecure. Use https instead.

Using clear-text protocols is security-sensitive **typescript:S5332**

Status: To review
This security hotspot needs to be reviewed to assess whether the code poses a risk.

Review

Review priority:
Low

Category:
Encryption of Sensitive Data

Assignee:
Not assigned

Where is the risk? | Activity

data/static/codefixes/redirectChallenge_1.ts

```
1  export const redirectAllowlist = new Set([
2    'https://github.com/juice-shop/juice-shop',
3    'https://blockchain.info/address/1AbKfgvw9psQ41NbLi8kufDQTezwG8DRZm',
4    'https://explorer.dash.org/address/Xr556RzuwX6hg5EGpkybbv5RanJoZN17kW',
5    'https://etherscan.io/address/0x0f933ab9fcaaa782d0279c300d73750e1311eae6',
6    'http://shop.spreadshirt.com/juiceshop',
     Using http protocol is insecure. Use https instead.
7    'http://shop.spreadshirt.de/juiceshop',
8    'https://www.stickeryou.com/products/owasp-juice-shop/794',
9    'http://leanpub.com/juice-shop'
10 ])
11
12 export const isRedirectAllowed = (url: string) => {
13   let allowed = false
14   for (const allowedUrl of redirectAllowlist) {
15     allowed = allowed || url.includes(encodeURI(allowedUrl))
16   }
```

Show next few lines of code